

Vulnerability Assessment Report

Database Server Security Analysis

System Description

The system under assessment is a business-critical database server that stores and manages sensitive customer and organizational data. The server is internet-accessible, connects to multiple internal applications, and is accessed by employees using shared credentials over an unencrypted connection. The attack surface includes the server hardware, its operating system, the database management software, network interfaces, and all dependent applications.

Scope

This assessment is limited to the confidentiality, integrity, and availability of the data stored on and transmitted to/from the database server. Physical security of the server hardware and the security of unrelated IT systems are outside the scope of this report.

Purpose

The purpose of this vulnerability assessment is to identify and evaluate security risks to the organization's database server, which handles sensitive customer records and financial data. The server has been flagged due to known configuration weaknesses, including open public access and use of shared credentials without encryption. By systematically analyzing potential threat sources and events, this assessment aims to provide the organization with a clear understanding of its risk exposure and actionable recommendations to reduce the likelihood and impact of a data breach or service disruption.

Risk Assessment

Threat Source	Threat Event	Vulnerability	Likelihood (1–3)	Severity (1–3)	Risk (L×S)
External Hacker / Cybercriminal	Unauthorized access via brute-force or credential stuffing attack on the publicly accessible server	No MFA; server exposed to the internet with shared, potentially weak credentials	3	3	9
Malicious Insider / Disgruntled Employee	Intentional data exfiltration or deletion of sensitive customer records	Overly permissive access; employees share credentials, making accountability impossible	2	3	6
Natural / Environmental Hazard	Server downtime or data loss due to power failure, hardware fault, or physical disaster	Lack of documented disaster recovery plan or redundant backup systems	1	3	3

Approach

This assessment uses a qualitative methodology, relying on expert judgment and the NIST SP 800-30 Rev. 1 framework to estimate the likelihood and severity of each identified threat. The three threat sources were selected because they represent the most realistic and impactful risks to this specific server configuration: external attackers are motivated by the value of the data and face minimal authentication barriers; insiders already have access and the lack of individual accountability through shared credentials makes this threat particularly difficult to detect; and environmental hazards represent a fundamental availability risk given the absence of redundant infrastructure. Together, these threats cover the full CIA triad — confidentiality, integrity, and availability — making them the highest-priority risks for the organization to address.

Remediation

To address the identified risks, the organization should immediately restrict public internet access to the database server and enforce multi-factor authentication (MFA) alongside individual user accounts to eliminate shared credentials — this directly mitigates the top-rated risk of external unauthorized access. Applying the principle of least privilege and implementing an Authentication, Authorization, and Accounting (AAA) framework will reduce the insider threat by ensuring actions are traceable to specific individuals. Finally, a defense-in-depth strategy should include encrypted backups stored off-site and a tested disaster recovery plan to maintain data availability against environmental threats. Public key infrastructure (PKI) should also be deployed to encrypt data in transit, protecting sensitive records from interception during network communication.